

A Call for a New Privacy & Security Regime for IoT Smart Toys

1st Joshua Streiff

*Luddy School of Informatics, Computing, and Engineering
Indiana University Bloomington
Bloomington, Indiana, USA
jostre@iu.edu*

2nd Naheem Noah

*Ritchie School of Engineering and Computer Science
University of Denver
Denver, Colorado
Naheem.Noah@du.edu*

3rd Sanchari Das

*Ritchie School of Engineering and Computer Science
University of Denver
Denver, Colorado
Sanchari.Das@du.edu*

Abstract—The current set of reactive regulatory agencies, legal protections, and market forces have proven inadequate for managing the security and privacy of the Internet of Things (IoT). Given the ubiquitous nature of IoT devices, current cybersecurity and privacy laws fail to enforce the protections of the data of vulnerable populations. The most vulnerable of these users are children, who are at the most significant risk of harm and least adequately protected by the current regime of controls for devices such as smart toys. In this paper, we review the currently existing regulatory and legal controls related to IoT devices while giving a brief overview of privacy & security policies that govern the data access, retention, and usage policies of children's smart toys. We detail the impact of such security and privacy vulnerabilities by conducting three case studies on IoT smart toys, including FisherPrice's SmartBear, Spiral Toys CloudPet Unicorn, and Owl's SmartWatch. Finally, we establish reasons for the complete restructuring of the responsibilities, requirements, and proactive options for implementing cybersecurity rules by IoT device manufacturers.

Index Terms—Privacy Policies, Cybersecurity Laws, Internet of Things, Smart Toys, COPPA, Case Studies, Vulnerable Population, Children.

I. INTRODUCTION

Cybersecurity and privacy are significant concerns for users and technological experts, especially when it comes to digital tools and technologies [23], [26]. However, when device users are children, the topic is of more significant concern as they are more prone to cyber-attacks than other populations, and such cyber-attacks can have far-reaching mental health impacts [34]. Furthermore, with digital evolution, as children are introduced to the interconnected digital world and its benefits, they are also exposed to vulnerabilities and risks, primarily through internet-connected devices [40]. The internet undoubtedly offers children opportunities to access educational information as well as entertainment; however, it is difficult for children to assess the risks involved in traversing the internet and digital systems as these may be invisible risks which can nonetheless impact their privacy significantly [22], [39].

In terms of digital technologies, the Internet of Things (IoT) is a rapidly developing market that holds great promise, from the enhancement of lives through medical devices, to promoting smart home and entertainment of children [35], [37]. 15 billion devices were connected to the internet in 2015, and this number could increase to 73 billion in 2025, as shown in Figure 1. However, it introduces several risks ranging from surveillance, data breaches, and manipulation. As the market of IoT devices continues to grow exponentially, the risks involved increase. IoT devices have been an instrument for domestic abuse, as quite a number of these devices are easy to compromise, and they reveal information about people, their homes, and personal information [9]. It is scary to imagine the impact of such breaches on vulnerable populations such as children.

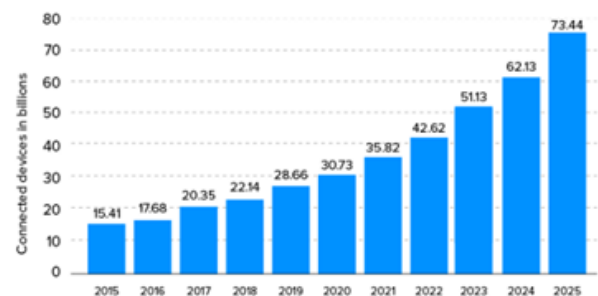


Fig. 1. IoT Worldwide Device Usage

According to Hessel et al., connected toys for children includes children's smartwatches, tablets, and monitoring devices [20]. IoT-connected toys often contain embedded cameras and microphones capturing children's reactions with or without their awareness or consent. These connected toys can be used to perpetrate cyber attacks against children [9]. These toys leverage Wi-Fi or Bluetooth to transfer data across

the cloud based on their functionalities. "Hello Barbie" and "My Friend Cayla" are examples of toys that capture voice recordings and transmit them over the internet.

The data processing involved does not happen on the device itself due to the computing power involved, and cloud servers leveraged in the past have been compromised. Hackers have acquired children's information on a large scale [20]. Lack of security measures in IoT devices resulted in the loss of profile information of six million children and voice recordings of 1.2 million children in the VTech hack of 2015 [20], [21]. "My Friend Cayla" had a Bluetooth microphone and speaker embedded; the Bluetooth device lacked any form of authentication, thereby enabling any Bluetooth-connected device within the toy's range to use the microphone and speaker inside the doll [21].

Our research included a review of the evolution of IoT devices, especially children's smart toys and how they exploit children's privacy. We reviewed the existing regulatory and legal controls deployed on IoT devices and how they have failed to establish children's protection, especially in the areas of privacy and security policies that govern the data access, retention, and usage policies of children's smart toys. After looking closely at security and privacy vulnerabilities introduced by three toys: FisherPrice's SmartBear, Spiral Toys' CloudPet Unicorn, and Owl's SmartWatch, we recommended creating a new privacy and security regime for IoT devices.

In this paper, section II details our investigation of the currently available legal framework limiting child abuse and harassment online, their successes and limitations, as well as the risks introduced by the use of IoT devices. Section III further details the impact of current regulatory and legal controls related to children's toys, and we present case studies in IV. Section V addresses the issue of reactionary protections versus preemptive protections and investigates the current pre-market testing techniques.

II. RELATED WORK

Prior work related to our research discusses the cybersecurity and privacy landscape before the advent of IoT and the infrastructure of IoT devices.

A. Pre-IoT: How We Got Here

The internet has long provided a benefit to children while also being a source of risk. Since its earliest days, the internet has been used as a tool for the furtherance of child exploitation and harm [3]. Initially, this harm primarily manifested in sharing illegal images to further offline criminal activity. However, with the growth of the internet and the introduction of cameras and sensors in the proximity of children, tools have been in place for the direct exploitation of children through avenues of sexting, blackmail, and digital harassment via online chatrooms, online gaming, and social media [33], [50]. These problems accelerated with the wide adoption of mobile devices (iPhones, Androids, etc.), which allow for unmonitored use of communication and video recording in the hands, homes, and bedrooms of children worldwide [24].

Cybersecurity and Privacy laws have attempted to address the resulting cases of child abuse and harassment [27]. Initial efforts had little success in addressing predatory activity and were characterized as spotty, isolated, and lacking technical skills. Their successes were sporadic and limited by jurisdiction. These efforts primarily aimed at stopping the transfer of child pornography and often misapplied the logic of self-victimization of children resulting in youth being charged with being their own victimizers [5], [36].

Initially, children were ruled as not being their victimizers in sexting, and several states have moved to a graduated system that modifies the usual rules of under-aged, illicit images [53]. These are done in parallel with sexual consent laws and have a minimal allowance (the individual who took the image and one other), and are now being combined with robust anti-sexting education in schools [48].

Secondly, in 2005, the federal government passed the Child Online Privacy and Protection Act (COPPA) which was intended to address web-based, online activities of children [16]. While this law has shown some success, especially when paired with educational efforts, it lacks impact as it is most commonly implemented through a self-reported age requirement easily bypassed by either the child or a parent on behalf of a child [41]. This is the legal groundwork underlying the explosion of the internet of things, the wide adoption of social media, and the use of cloud-based services.

B. Applying Law to Technological Chaos

The Internet of Things (IoT) presents a set of new challenges to children's digital safety [32]. These challenges resulted based on the number of communication technologies available to children, the ubiquity of the presence and use of IoT devices, and the proximity of technology to child and child spaces. All of which combine with a lack of public understanding of the variety of threat surfaces, risks, and even the most limited mitigation strategies that users have available to them [45].

IoT has continued to grow in market penetration, increasing usage levels. As previously mentioned, connected devices numbered 15 billion in 2015. They represented 35 billion in 2020 and are expected to reach 73 billion by 2025 [1]. These numbers constitute devices ranging from mobile devices to medical devices, from infrastructure and military-supported devices to those used in academic and athletic arenas, all found in public and private places, including children's school classrooms and bedrooms. Consciously and unconsciously, we all interact with IoT devices daily, from phones sharing data directly with a COVID contact tracing application, to lights in buildings being turned on and off through BLE-driven sensors in homes and offices. The ubiquity of the usage of IoT devices is a significant indication of inescapability [25].

IoT's ubiquity is matched in its multivalent modes of communication [25]. Unlike earlier technological models, IoT is not tied to a singular form of communication. The mode of data and information transfer is not entirely transparent to users who are used to seeing the network their laptop is

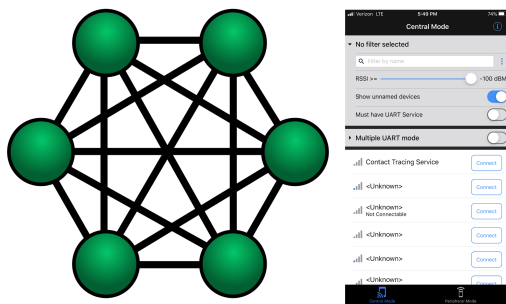


Fig. 2. Mesh Network Layout and Sample BLE Scan of Nearby Devices

attached to and what data is being stored at what location. IoT instead uses a wide range of communication protocols beyond simple WiFi. They include short-range technologies like Bluetooth, Bluetooth Low Energy (BLE), and Zigbee. The medium range technologies include LTE, WiFi, and 2G through 5G. Long-range technologies include but not limited to LoRA, LET-M, NB-IoT, and Wize [47]. Each of these protocols, and the hardware tools driving them, presents an attack surface that the average individual has little or no knowledge of.

Every IoT device may be using more than one of these protocols simultaneously, making pairings with devices near it without indicating that activity to the user. Short of turning off given protocols and forgoing all activity on that protocol/bandwidth and disabling device applications, users have no awareness or control over these communications, granular or otherwise. These connections constitute ad-hoc mesh networks with devices talking one to another and the data moving between them, back to applications/programs, and eventually stored in a cloud database. The existence and use of mesh networks are not new in informatics, but their growth and use are. Mesh networking is a cybersecurity challenge. It does not involve direct user interaction, nor is there transparency at the moment of transmission, the availability of connection, or how it can be addressed. One visible example of this threat was the harassing use of Apple's AirDrop by nearby individuals to send nude images to victims on buses and other public transport. Until Apple changed the default settings, women were "flashed" by users who were within the immediate and enclosed space of public transportation¹. Figure 2, shows how devices are connected through a mesh network and an example of Bluetooth low energy scan for nearby devices.

However, the data transferred between IoT devices presents an additional risk as it is typically sent to an internet-based Cloud server. The process is opaque: not only due to lack of clarity regarding the data sent but also the eventual usage [38]. As Amazon's Alexa demonstrates, IoT devices that listen at all times for an action word record far more than is intended by users; that data is stored unbeknownst to most users and has repeatedly been available for access by Amazon workers

¹<https://nakedsecurity.sophos.com/2017/08/17/woman-targeted-with-120-images-on-public-transport-via-airdrop/>

for both legitimate and illegitimate uses [38]. Furthermore, how aggregate data is used once anonymized is unknown despite work by researchers to identify output points on data of known generation. IoT Cloud data collection and storage are amorphous, but it is also unsafe in storage from improper setup, poor server-side security, and unencrypted data transfer.

Even anonymized IoT data presents technical challenges due to the large volume of devices, protocols, APIs, and applications interacting with each other: with surprising data leakage even from anonymized data. As demonstrated by the Strava heat maps' accidental mapping and sharing of secret military bases worldwide and resulting in the banning of IoT fitness devices from military bases, data can present very serious personal, military, and governmental risks even when anonymized. In the case of the Strava heat map, users believed that they had opted out of their data being used for data analytics but had not. In addition, IoT causes unexpected interactions of devices and data analytics. For example, the Strava team did not predict that their product would unmask special forces bases in Syria and Africa any more than Alexa expected their product to be able to take instructions from sources other than the owner of the device. IoT's ubiquity and mass data gathering lead to unexpected and often adverse outcomes.

III. EXISTING LEGAL FRAMEWORK

IoT devices that are targeted at and designed for children present all of the threat surfaces and structural failings found in the overall IoT ecosystem [45]. They also have risks specific to children's age, cognitive abilities, isolation from products, and existence as an at-risk population for many on and offline threats. IoT toys and youth-owned devices have been found with active threats, including strangers communicating with children, location discovery with or without online sharing, unauthorized video and audio recordings, cloud data stolen to include usernames, passwords, and audio/video recordings, and in specific cases children blackmailed, sexually exploited, and lured from homes. The attack surfaces in IoT toys vary as widely in range as with IoT devices, in both short-range attacks and those separated by international borders. Data, even anonymized data, can be used to discover the location and activities of children [29]. A challenge in the IoT toy space is that the user of the product is not synonymous with the person responsible for the product [28]. In the following subsections, we review existing legal frameworks revolving around IoT, children, and Cybersecurity and the drawbacks of those frameworks.

A. USA's COPPA & FTC

Primary approaches to Cybersecurity in the US are the Children's Online Privacy and Protection Act (COPPA), the Federal Trade Commission (FTC), and most recently, California's Internet of Things Security Law (CITSL). Each has a separate area of application and function and has recorded some level of success in mitigating much of the worst cybersecurity risks facing children today; however, none have

succeeded in very fundamental areas of child protection [19]. COPPA is the primary US law on digital child safety in the US [51]. Regulating the network use by and data traffic of children at the age of 12 or below has proved to be an excellent first step in child safety. It was the first tool that codified pre-teen children's particular security needs and recorded some levels of adaptation as risks against those children have grown, including the emergence of IoT. It also has had some success in fundamentally reworking how media companies handle youth, as best exemplified by youtube's profound changes in marking adult-related content, removing comments from youth-only videos, and addressing marketing concerning children. These should be recognized as significant successes [31]. COPPA, however, has significant failings. It is primarily a network traffic tool, and while it has been changed somewhat to address IoT, it is still primarily aimed at websites. Additionally, most implementations of COPPA rules allow them to be bypassed either by an adult who signs in their birth date on behalf of a child or by children self-reporting their age inaccurately, which parents, users, and designers all know will happen in reality [30]. COPPA fails because we teach children to falsify information [12].

The USA FTC plays a clear role in maintaining a fair and safe marketplace for all digital products and related user data. They do have the ability to cite companies for breaches and failures in security. Their bark, however, is more significant than their bite - at least on initial citations, which are capped at no more than USD 45,000 [7], [43].

For large companies, this is not a financial threat, and as we have seen with Facebook, even hefty penalties for repeated citations are not adequate to curb corporate misbehavior. With smaller companies (as we will see in the Spiral Toys case), the threat of an FTC filing does affect them, but instead of mitigating the design of a product, smaller companies may simply decide to brand dissolve and abandon their product base. Additionally, the FTC is not a consumer protection organization. Its mandate is to protect a "fair" commerce market, not to protect individuals from poorly implemented IoT. In order to bring an FTC investigation, one must show proof of standing, which includes an incident of harm that can be traced to an actual device and a criminal incident or a failing so egregious that the likelihood of harm is evident that standing would be granted. In reality, this means that the FTC has shown itself to be helpful in IoT security after a large entity, like Mozilla, has spent the money and research time to prove the danger of a product [43]. One measure of note that does stand as a significant precedent is the FTC's use of "deceptive acts" as applied to a "material omission" in which the user had no way to avoid a negative outcome. An example is the TRENDnet webcam case [43]. Given that IoT Toy purchasers have little to no information about the sensors in the toys, the lack of information given at the time of purchase should represent a material omission and violation.

B. Improved Solutions: California's IoT Security Law & GDPR

California's Internet of Things Security Law (CITSL) is a significant move forward in the legal identification of IoT items and in codifying a set of "reasonable security" requirements for products to adhere to in their design [14]. It covers any product with an electronically identifiable ID via IP or Bluetooth (i.e., Mac Address), which covers most but not all traditionally networked products and IoT devices using ad-hoc mesh networking. For example, CITSL defines "reasonable security" in passwording as a requirement that the device employs one of the following two features; unique passwords for every device, and/or passwords can be changed by the user [46]. The CITSL standards are not stringent; they are a starting point. Additionally, as CITSL only covers WiFi and Bluetooth-enabled devices, it will need to expand into other modes of communication if it is to be adequately nimble to keep up with the IoT it seeks to regulate. Less than a solution, it is a framework for future national regulations to follow. The introduction of the GDPR has had many impacts on IoT manufacturers. GDPR has three areas, in particular, that impact IoT device design: consent, data ownership/destruction, and required updating. These are all vital aspects of Cybersecurity, but their application to IoT is less than clear.

Questions arise such as: How does one consent to an IoT Toy? Does the child consent? Can a child legally consent? Under the GDPR, parents do not have the absolute right to consent on behalf of their children in posted images, so do they have the right to consent for their child in a toy that only the children will interact with? What interaction constitutes consent - simply clicking the ok button, turning the product on, or lying about a birthdate? EU GDPR makes it clear that individuals fundamentally own the data about them, including images, and provides owners of data the right to have that data removed from the internet [13]. It is very unclear how this will be implemented in camera-enabled IoT devices such as doorbells, refrigerators, and Roombas [44], [49]. Some of the questions that need to be answered are if there would be a mechanism on the device for removal or just from Cloud servers? Will there finally be transparency in Cloud server storage? Required updating features also raises questions, as not all IoT devices have direct access to updates. While a smart fridge may have direct internet access via a home WiFi network and can update automatically, the same is not true of the Bluetooth humidity detector, which has no WiFi capability. The requirement will likely push updates to flow through their related mobile applications. Of the three requirements, this is the one that is least technically challenging [44], [49].

The GDPR helps to provide for significant financial penalties for violations of data security or privacy violations, and these have the attention of companies that otherwise would ignore the penalties of the FTC [49]. While this is proof of the effectiveness of increased financial penalties, and the GDPR has moved privacy and data ownership into the modern age, the fundamental problems of the GDPR remain the

implementation challenges, only affecting the EU. As with the US agencies previously mentioned - all of these mechanisms are reactive, not proactive [44].

IV. CASE STUDIES: SMART TOYS



Fig. 3. Case Examples FP Bear, Cloudpets Unicorn, & M2 Watch

As a method of measuring effectiveness, we evaluated three IoT toys released in the US in 2015. They are the FisherPrice (FP) Smart Bear ², Spiral Toys' Cloudpets Unicorn ³, and Owl's smart watch ⁴. Figure 3 shows the image of these toys. Our evaluation method pairs direct investigation of the devices by researchers of this work guided by relevant preexisting security failure discoveries noted in print to verify their findings [2], [8], [11]. All three devices have modes of communication consistent with California's definition of IoT devices. Each of these toys subsequently had one or more security vulnerabilities discovered with mixed results on mitigation [45]. All of these toys are still in the hands of children.

FP's Smart Bear communicates via WiFi and Bluetooth. Its sensors include a camera, microphone, accelerometer, and a hug detecting pressure plate, all controlled by a modified Android tablet with a 32GB hard drive. Children interact with the toy through rudimentary voice recognition and cards that the players hold in front of the toy's nose camera to initiate specific gameplay. Unbeknownst to users, the full-color video camera functions in an always-on state while not indicating camera activity either by notification light or disclosure in the user manual. In 2016, Rapid7 researchers proved that data sent to the cloud utilized no encryption, allowing capture of usernames, passwords, and sensor data which FP did fix through a subsequent update [4]. In 2018, IU researchers discovered a method allowing the installation of remote access software to control the toy remotely if given physical access to the toy for a few minutes. The attack surface was in an unprotected USB port, coupled with an intentionally modified operating system with no username or passwords and Android OS USB Debugger access turned on by default. After verification from Consumer Reports, FisherPrice opted to make none of the three mitigations advised by the IU team [45]. Throughout the sales history of the FP Smart Bear, parents were not notified of the camera in the bear's nose. Nor does the bear have a light indicator that shows when the camera is running, a feature common among laptop cameras and expected by customers.

²<https://www.fisher-price.com/en-us>

³<https://www.thetoystore.com/animals/pets/Cloud-Pets-36cm-Interactive-Soft-Toy-Unicorn/p/528012>

⁴<http://owlcole.com/>

The lack of camera notification is particularly critical as the toy's camera runs any time the toy is turned on. None of the toy's packaging makes this "always on camera" state clear, leaving parents with a significant material omission that could have guided gameplay or purchasing decisions.

Spiral Toys' (STOR) Cloudpets Unicorn was released in 2015. It exclusively utilizes Bluetooth Low Energy (BLE) for communications. Its sensors include a microphone and pressure-sensitive pads on the toy's arms. The toy allows children to record voice messages sent via a nearby phone to a parent's phone far away. That parent can then listen and record a new message that returns to the child's toy [45]. In 2016, the database storing user information was discovered on a public server, and 800,000 user accounts with 2.5 million audio recordings were stolen. By 2017, researchers had discovered BLE vulnerabilities that allow attackers to find the toys and communicate with children with no credentials required [17]. After a Mozilla investigation in 2017-2018, Amazon and eBay removed the toy from their sites and Spiral Toys dissolved as a brand in 2018 [8]. Nonetheless countless Cloudpets remain in children's hands and are at risk of location and communication attacks [42].

Shenzhen SMA M2 smartwatches, most recently released under the Owl Cole brand, have cameras and a GPS location sensor [2]. Parents can use the watch data to locate their children on a web map. In 2019, researchers were able to discover the location of any of the 5,000 children using the watches on any given day due to failures in the Web API's authentication and authorization controls as well as unencrypted communication [11]. After verification that the watches also failed to comply with GDPR requirements, the EU distributor, Pearl, successfully forced updates to the watch that increased their security [8]. Some EU locations have chosen to remove these watches from the sale.

In each of these devices, we find a surprising lack of basic computer security practices: lack of encryption, lack of authentication, poorly written Web APIs, private cloud data stored publicly, discovery avenues for locating children, and in the case of the FP Toy Bear a lack of camera use notification [15], [18], [45], [52]. Post notification, one company made minimal changes, one dissolved their brand, and one provided updates. Of the three, only one product received all of the improvements advised by researchers, while all three of these toys remain in use by children and families unaware of the risks they pose. These cannot be considered success stories. Additionally, the fundamental problem is that the current regimen is reactive, only addressing risk as vulnerabilities are found, or children are harmed. While it is true that the regulatory penalties of the GDPR or an enhanced COPPA could have an effect on long-lasting brands with much to lose, and the FTC can wield sufficient penalties to collapse a brand like Spiral Toys; the toys themselves remain in the hands of children as risks. Table I summarizes the security failure of the IoT smart toys.

	Smart Toy Bear	CloudPet Unicorn	Cole Owl
Wifi Traffic	Unencrypted (Initially)	None	Unencrypted (Initially)
BLE Broadcast	None	CloudPet	None
Authentication	None	None	None
Authorization	None	None	None
Unprotected Connection Ports	USB	None	None
Always On Camera	Yes	None	None
Failure to Identify Mic On	Yes	Yes	No
Failure to Identify Camera On	Yes	N/A	No
Remotely Controllable	Yes	Yes	No
Location	Identifiable	Identifiable	Identifiable
Cloud Data	Protected	Unprotected	Unprotected

TABLE I

SNAPSHOT OF THE SECURITY FAILURES OF THE THREE DEVICES

V. DISCUSSION

A. Parallel Existing Regulatory Approaches

It would be inaccurate to state that IoT toys receive no testing before they are released for sale in the United States. They are, in fact, rigorously tested by the FCC which is entrusted with protecting the nation's communications channels [8]. Our case study toys were submitted for FCC testing and detailed schematics, including operations descriptions, wiring pinouts, and other technical documentation. Testing then verified that the internal radios complied with national safety standards so that no frequency bleed or misuse of bands is made during toy use [10]. Detailed disassemblies are done, images are taken, and much of the data is held in privacy if adequately requested by the submitter.

This testing is done pre-sale, which is necessary to protect communications infrastructures. Pre-sale testing is not unique to the FCC. California uses a parallel but unrelated system for handgun sales. Under the California Code of Regulations, title 11, section 4070, California provides a list of firearms that have been tested and approved for sale. The list is amended with items being added and removed with frequency [6].

B. Concrete Solutions to Save Children via the FCC

In our case study examples, we see that none of the existing legal and regulatory strategies are adequate to prevent a dangerously compromisable toy from being alone in the hands of a child. FP's brand concern was adequate for them to fix unencrypted data transfer but not adequate to issue a firmware update that created a username/password requirement for installing software on the toy. Spiral Toys incompetently ignored warnings before their database was stolen. They decided to collapse their brand after Mozilla's investigation which initiated the threat of FTC involvement as well as the removal of their toys from the Amazon and eBay marketplaces. Their dissolution left unsafe toys in children's hands. Shenzhen's watch line continues to be sold online with some updates, but there are no federal test results to verify the devices are now safe. At best, each of these is being addressed at some point, in some way, over the lifetime of the toys in children's hands; meanwhile, the toys present clear and direct risks to children while testing is ad-hoc, at best, by private parties. None of these reactive responses succeeded in making children safe from the toys when they were first taken out of their box.

What we need is a proactive response for IoT devices. This is a necessary goal as IoT Toys are explicitly sold for an at-risk population; they are items that can cause harm to that population and can easily be measured against a set of testable requirements. The most easily implemented mechanism would tap into the FCC's current testing mandate and add IoT security testing to their FCC ID testing regimen. The expansion is logical as these products already have their mechanisms tested for their use of regulated frequencies. They transmit data in specifically allowed ways without causing collateral damage in the transmission. In this analysis, it is easy to argue that FCC testing should have already included the software mechanisms of transmission and hardware mechanisms of transmission. There is clear precedent for FCC testing and intervention, as best demonstrated in the FCC's recent ruling on Huawei 5G technologies ⁵. Having reviewed Huawei's technologies, the FCC has ruled that their products present threats to US national security, thereby barring US companies from using or implementing these products. This was done within the current FCC umbrella. It is no stretch to expand the FCC's responsibilities slightly in order to increase the security of children interacting with products clearly labeled for ages 12 and under. As the FCC is already testing these products per the FCC ID process, adding cybersecurity baselines for testing should present minor logistical challenges.

C. IoT Toys Minimum Security Requirements

Internationally, nations have struggled to balance an industry-led set of standards. Japan's model of industry self-regulation stands as the polar opposite of South Korea's government regulation model [43]. The GDPR gives strong measures for personal data and cloud storage, while the US has California's IoT regulations and the NIST standards to draw from [43]. Given the problem's immediacy, a melding of these various regimens will produce the needed minimum standards for immediate implementation. In contrast, the second set of more ambitious privacy and security standards would need time to be included in future projects by today's design teams. These standards draw strongly from ISOC and Mozilla-supported standards but include GDPR items and one item from the FTC, as mentioned earlier, per its policy on "deceptive acts."

⁵<https://www.reuters.com/article/us-usa-china-telecom/u-s-fcc-issues-final-orders-declaring-huawei-zte-national-security-threats-idUSKBN24130A>

1) *Stage 1: Immediate Minimum Standards:* 1. Encrypted communications and data storage, including during setup. 2. Clear descriptions of sensors, communication mechanisms, and data storage locations placed on packaging and manual. 3. Security updates capability. 4. Unique passwords at levels and communication ports and changeable passwords at the user level. 5. Implementation of full user based ACL with both authentication and authorization.

2) *Stage 2: Future Minimum Standards (3 years after initial implementation:* 6. Clear mechanism for cybersecurity-based recall. 7. Clear continuing responsibilities. 8. Privacy policy practices listed in manual. 9. An independent right to be forgotten, implementable by children once they reach age 18. 10. Child-appropriate communication of toy sensors and safety.

Stage one addresses the most vitally needed security and transparency problems common to IoT Toys today. Items 1, 4, and 5 are standards supported by NIST and ISOC. Item 2 is a solution derived from the FTC that identified the problem of user notification. As a result, for any purchase in a "fair marketplace," the parent must know about purchased sensors. This would prevent hidden cameras, microphones, accelerometers, and other data-collecting devices from entering a home without parental consent. Item 3 is from the GDPR. Stage two brings toys rights to data and continued threats. Items 8 and 9 are in line with GDPR provisions. Items 6 and 7 are in line with manufacturer requirements in the automotive industry and would eliminate the ability of the industry to shirk responsibility for older products. Finally, item 10 is a continuation of Stage one's requirement to inform parents, expanding that requirement to the device's actual user.

D. What Comes Next in IoT Toys?

The future of IoT is challenging to predict. It is tied to technological and social change; IoT is inherently exceedingly agile and lends itself to entrepreneurial experimentation. There is clarity that IoT is quickly expanding into every corner of home health care and remote health monitoring, a process that began before COVID19 but has accelerated dramatically since the advent of quarantining measures. Expansions into remote education, both in educational materials and proctoring tools, are also expected to have significant needs that IoT will work to supply solutions to. In their private spaces, these will significantly impact children, have implications for their educational futures, and be full of sensitive information. It is noteworthy to mention that an executive order (14028) issued in 2021 required an evaluation of IoT security in the marketplace, which we plan to implement in the extension of this work.⁶

The growth of low energy sensors communicating through BLE affords an increase in the volume of individual IoT devices working in conjunction with each other. In addition, assistive devices such as the Alexa make ubiquity and opacity ever more a concern. While we cannot predict the exact

nature of future IoT toys, we can expect that (1) most toys will become IoT, (2) these devices will interact with each other, (3) they will collect increasingly invasive amounts of data, (4) they will store it in opaque fashions, (5) they will carry impacts beyond the lifetime of those toys in marketing and educational futures, and (6) they represent serious direct risks to child safety when they are inevitably hacked.

VI. CONCLUSION

With the sporadic evolution of IoT devices, it is evident that the threat to users, especially children, will continue to increase. Even though some available legal frameworks have provided a certain degree of safety to children, more work is needed in IoT security and privacy. Based on our case studies with FisherPrice, Spiral Toys, and the Owl, we demonstrate vulnerabilities including lack of encryption, lack of authentication, publicly stored data, and discovery avenues for locating children in physical space. Based on this, we propose immediate and future minimum standards that integrate existing policies from ISOC, Mozilla standards, GDPR, and the FTC. These policies include; encryption of communications and data storage, clear description of sensors, changeable passwords, improved authentication and authorization, privacy policy practices, option to be forgotten, and clear communication of sensors and safety.

VII. FUTURE WORK

We conducted three case studies to understand the need for new privacy and security regimes for IoT smart toys. Our following steps are to conduct a detailed security evaluation and user study focused on identifying the parts of a pre-market unified certification regimen for IoT toys. In addition, existing third-party product testing stakeholders (UL, Consumer Reports, etc.) and FCC-connected testing contractors need to be identified and brought together for gap identification in testing. Thus, we plan to collaborate with industries, policymakers, and academic researchers to build secure IoT toys.

ACKNOWLEDGEMENT

We want to thank Dr. Scott J. Shackelford and Dr. L. Jean Camp from Indiana University Bloomington (IUB) for their valuable feedback and resources to conduct the research. We would also like to acknowledge the Inclusive Security and Privacy-focused Innovative Research in Information Technology (InSPIRIT) Laboratory at the University of Denver (DU). We would also like to thank Elizabeth Drake, Julia Kalshoven, Ruth Krueskamp, and Clare McCarthy from the United States Annapolis Naval Academy for their initial contribution in part of this research. Any opinions, findings, conclusions, or recommendations expressed in this material are solely those of the authors.

REFERENCES

- [1] ALAM, T. A reliable communication framework and its use in internet of things (iot). *CSEIT1835111— Received 10* (2018), 450–456.
- [2] ASIF, S. This smartwatch is exposing real-time location data of thousands of kids, Dec 2019.

⁶<https://csrc.nist.gov/publications/detail/white-paper/2022/02/04/criteria-for-cybersecurity-labeling-for-consumer-iot-products/final>

- [3] ATAMLI, A. W., AND MARTIN, A. Threat-based security analysis for the internet of things. In *2014 International Workshop on Secure Internet of Things* (2014), IEEE, pp. 35–43.
- [4] BRILL, H., AND JONES, S. Little things and big challenges: information privacy and the internet of things. *Am. UL Rev.* 66 (2016), 1183.
- [5] BURKE, A., SOWERBUTTS, S., BLUNDELL, B., AND SHERRY, M. Child pornography and the internet: Policing and treatment issues. *Psychiatry, Psychology and Law* 9, 1 (2002), 79–84.
- [6] CENTER, G. L. Design safety standards in california, Mar 2021.
- [7] CHOSLOVSKY, J. Agency review of health care industry mergers: Proper procedure or unnecessary burden. *Admin. LJ Am. U.* 10 (1996), 291.
- [8] DAILYMAIL.COM, M. C. F. Amazon kills off the cloudpet: Firm dumps smart toys over security concerns, Jun 2018.
- [9] DATTA BURTON, S., TANCZER, L. M., VASUDEVAN, S., HAILES, S., AND CARR, M. The uk code of practice for consumer iot cybersecurity: where we are and what next. *The PETRAS National Centre of Excellence for IoT Systems Cybersecurity* (2021).
- [10] DESOUSA, K. C., DENFORD, J. S., AND KRISHNAMURTHY, R. How the us federal communications commission managed the process of its modernization. In *Digitalization Cases*. Springer, 2019, pp. 411–428.
- [11] EGEA, J. A. L. Framework based on parameterized images on resnet to identify intrusions in smartwatches or other related devices. *The Bible of AI™ OpenScience • Authors' publications* (2020).
- [12] ENGST, A. How coppa teaches children to lie, Nov 2011.
- [13] ESKENS, S. A right to reset your user profile and more: Gdpr-rights for personalized news consumers. *International Data Privacy Law* (2019).
- [14] GEORGE, D. Iot manufacturers – what you need to know about california's iot law.
- [15] GIRVAN, N. *An Investigation into the Privacy and Security Risks of Smart Toys in New Zealand*. PhD thesis, Auckland University of Technology, 2020.
- [16] GRANDISON, S. The child online privacy protection act: The relationship between constitutional rights and the protection of children. *UDC/DCSL L. Rev.* 14 (2011), 209.
- [17] GREENBERG, J. Dangerous games: Connected toys, coppa, and bad security. *Geo. L. Tech. Rev.* 2 (2017), 170.
- [18] HAYNES, J., RAMIREZ, M., HAYAJNEH, T., AND BHUIYAN, M. Z. A. A framework for preventing the exploitation of iot smart toys for reconnaissance and exfiltration. In *International Conference on Security, Privacy and Anonymity in Computation, Communication and Storage* (2017), Springer, pp. 581–592.
- [19] HERSH, M. L. Is coppa a cop out-the child online privacy protection act as proof that parents, not government, should be protecting children's interests on the internet. *Fordham Urb. LJ* 28 (2000), 1831.
- [20] HESSEL, S., AND REBMANN, A. Regulation of internet-of-things cybersecurity in europe and germany as exemplified by devices for children. *International Cybersecurity Law Review* 1, 1 (2020), 27–37.
- [21] HOLZNAGEL, B., AND VIERLING, C. 2.2 instrumente des verbraucherschutzes in der netzregulierung. In *Verbraucherrechtswollzug* (2020), Nomos Verlagsgesellschaft mbH & Co. KG, pp. 75–88.
- [22] HOURCADE, J. P. Child-computer interaction. *Self, Iowa City, Iowa* (2015).
- [23] KHATOUN, R., AND ZEADALLY, S. Cybersecurity and privacy solutions in smart cities. *IEEE Communications Magazine* 55, 3 (2017), 51–59.
- [24] KNOWLES, B., FINNEY, J., BECK, S., AND DEVINE, J. What children's imagined uses of the bbc micro: bit tells us about designing for their iot privacy, security and safety. In *Living in the Internet of Things: Cybersecurity of the IoT-2018* (2018), IET, pp. 1–6.
- [25] KRČO, S., POKRIĆ, B., AND CARREZ, F. Designing iot architecture (s): A european perspective. In *2014 IEEE world forum on internet of things (WF-IoT)* (2014), IEEE, pp. 79–84.
- [26] LI, Y., XIN, T., AND SIPONEN, M. Citizens' cybersecurity behavior: Some major challenges. *IEEE Security & Privacy* 1, 01 (2021), 2–9.
- [27] LIU, B. C. C., AND VAUGHN, M. S. Legal and policy issues from the united states and internationally about mandatory reporting of child abuse. *International journal of law and psychiatry* 64 (2019), 219–229.
- [28] LO, M. A domestic violence dystopia: Abuse via the internet of things and remedies under current law. *Cal. L. Rev.* 109 (2021), 277.
- [29] LONZETTA, A. M., COPE, P., CAMPBELL, J., MOHD, B. J., AND HAYAJNEH, T. Security vulnerabilities in bluetooth technology as used in iot. *Journal of Sensor and Actuator Networks* 7, 3 (2018), 28.
- [30] MATECKI, L. A. Update: Coppa is ineffective legislation-next steps for protecting youth privacy rights in the social networking era. *Nw. JL & Soc. Pol'y* 5 (2010), 369.
- [31] MAYFIELD, J. Revised children's online privacy protection rule goes into effect today federal trade commission. *Federal Trade Commission* (2013).
- [32] MEHMOOD, Y., AHMAD, F., YAQOOB, I., ADNANE, A., IMRAN, M., AND GUZANI, S. Internet-of-things-based smart cities: Recent advances and challenges. *IEEE Communications Magazine* 55, 9 (2017), 16–24.
- [33] MITCHELL, K. J., WOLAK, J., AND FINKELHOR, D. Trends in youth reports of sexual solicitations, harassment and unwanted exposure to pornography on the internet. *Journal of adolescent health* 40, 2 (2007), 116–126.
- [34] PAINE, T. Virtual violence: protecting children from cyberbullying. *The Rights of Man* 2 (2009), 1–61.
- [35] PARK, E., DEL POBIL, A. P., AND KWON, S. J. The role of internet of things (iot) in smart cities: Technology roadmap-oriented approaches. *Sustainability* 10, 5 (2018), 1388.
- [36] PARTI, K. Transnational sex crime. In *Handbook of Transnational Crime and Justice*. SAGE Publications, 2013.
- [37] PERERA, C., LIU, C. H., JAYAWARDENA, S., AND CHEN, M. A survey on internet of things from industrial market perspective. *IEEE Access* 2 (2014), 1660–1679.
- [38] POYNER, I., AND SHERRATT, R. Privacy and security of consumer iot devices for the pervasive monitoring of vulnerable people. In *Living in the Internet of Things: Cybersecurity of the IoT-2018* (2018), IET, pp. 1–5.
- [39] QUAYYUM, F., CRUZES, D. S., AND JACCHERI, L. Cybersecurity awareness for children: A systematic literature review. *International Journal of Child-Computer Interaction* (2021), 100343.
- [40] RAHMAN, A., MALAYSIA, N., SAIRI, M., ZIZI, I., AND KHALID, F. The importance of cybersecurity education in school. *International Journal of Information and Education Technology* 10, 5 (2020), 378–382.
- [41] SCHWARTZ, T. The conundrum of coppa: Expecting our children to be principled about honesty while allowing them to falsify information.
- [42] SEALS, T. Cloudpets may be out of business, but security concerns remain.
- [43] SHACKELFORD, S. J., RAYMOND, A., CHAROEN, D., BALAKRISHNAN, R., DIXIT, P., GJONAJ, J., AND KAVI, R. When toasters attack: a polycentric approach to enhancing the security of things. *U. Ill. L. Rev.* (2017), 415.
- [44] SIRUR, S., NURSE, J. R., AND WEBB, H. Are we there yet? understanding the challenges faced in complying with the general data protection regulation (gdpr). In *Proceedings of the 2nd International Workshop on Multimedia Privacy and Security* (2018), pp. 88–95.
- [45] STREIFF, J., DAS, S., AND CANNON, J. Overpowered and underprotected toys empowering parents with tools to protect their children. In *2019 IEEE 5th International Conference on Collaboration and Internet Computing (CIC)* (2019), IEEE, pp. 322–329.
- [46] SUTHERLAND, E. D. M. I., AND KARGAARD, J. Iot security and forensics: A case study. In *ECCWS 2021 20th European Conference on Cyber Warfare and Security* (2021), Academic Conferences Inter Ltd, p. 278.
- [47] VAAS, AND LISA. Woman targeted with 120 images on public transport via airdrop, Aug 2017.
- [48] WICS/WRSP. Il lawmakers taking up bill adding 'sexting' to sex ed classes, Jan 2020.
- [49] WOLFF, J., AND ATALLAH, N. Early gdpr penalties: Analysis of implementation and fines through may 2020. *Journal of Information Policy* 11 (2021), 63–103.
- [50] YBARRA, M. L., MITCHELL, K. J., WOLAK, J., AND FINKELHOR, D. Examining characteristics and associated distress related to internet harassment: findings from the second youth internet safety survey. *Pediatrics* 118, 4 (2006), e1169–e1177.
- [51] ZAVALETTA, J. A. Coppa, kids, cookies & (and) chat rooms: We're from the government and we're here to protect your children. *Santa Clara Computer & High Tech. LJ* 17 (2000), 249.
- [52] ZHANG, J., CHEN, H., GONG, L., CAO, J., AND GU, Z. The current research of iot security. In *2019 IEEE Fourth International Conference on Data Science in Cyberspace (DSC)* (2019), IEEE, pp. 346–353.
- [53] ZHANG, X. Charging children with child pornography—using the legal system to handle the problem of “sexting”. *Computer Law & Security Review* 26, 3 (2010), 251–259.